

APPLIED PENETRATION TESTING ENGINEER

Final Project Report

Submitted By

Name: Sifat Akter

ID:2023100000506

Department: Computer Science & Engineering (CSE)

Course Code: CADS012

Project Title: External Security Assessment & Penetration Testing

Prepared For:

PosBuzz Retail Solutions

Date: 18 May 2026

Executive Summary

This report presents the findings from three practical security assessments conducted in controlled lab environments: Active Reconnaissance, OWASP Juice Shop, and the Blue (MS17-010) vulnerable Windows machine. The purpose of these exercises was to identify common weaknesses in networks, web applications, and operating systems and evaluate their potential impact.

The assessments revealed multiple security issues, including information disclosure, authentication bypass, SQL Injection vulnerabilities, and remote code execution through unpatched services. Successful exploitation demonstrated how attackers can gather sensitive information, gain unauthorized access, escalate privileges, and fully compromise systems.

These findings emphasize the importance of strong security practices such as timely patch management, secure application development, service hardening, and continuous monitoring.

Scope of Assessment

In Scope

- TryHackMe Active Reconnaissance Room
- OWASP Juice Shop Vulnerable Web Application
- Blue Windows Machine (MS17-010 / EternalBlue)

Out of Scope

- Real-world production systems
- Third-party infrastructure and services
- Denial-of-Service (DoS) attacks
- Social engineering activities

Methodology

The assessment followed a standard penetration testing lifecycle consisting of the following phases:

1. Reconnaissance

Information gathering was performed to identify live hosts, open ports, running services, and publicly accessible information.

2. Vulnerability Analysis

Discovered services and applications were analyzed for known vulnerabilities, weak configurations, and insecure coding practices.

3. Exploitation

Controlled exploitation techniques were used to validate vulnerabilities and assess their impact.

4. Post-Exploitation

Privilege escalation, credential extraction, and system access verification were performed to determine the extent of compromise.

5. Reporting

All findings, associated risks, impacts, and remediation recommendations were documented.

Active Reconnaissance Summary

Tools Used

- ping
- traceroute
- telnet
- netcat
- Browser Developer Tools

Key Findings

- Information disclosure through HTTP headers and JavaScript files
- ICMP responses revealed active hosts and possible operating system details
- Traceroute exposed internal routing paths and network structure
- Banner grabbing revealed service versions and technologies in use

```

user@AttackBox$ traceroute tryhackme.com
traceroute to tryhackme.com (172.67.69.208), 30 hops max, 60 byte packets
 1 ec2-3-248-240-5.eu-west-1.compute.amazonaws.com (3.248.240.5) 2.663 ms * ec2-3-248-240-
 2 100.66.8.86 (100.66.8.86) 43.231 ms 100.65.21.64 (100.65.21.64) 18.886 ms 100.65.22.160
 3 * 100.66.16.176 (100.66.16.176) 8.006 ms *
 4 100.66.11.34 (100.66.11.34) 17.401 ms 100.66.10.14 (100.66.10.14) 23.614 ms 100.66.19.2
 5 100.66.7.35 (100.66.7.35) 12.808 ms 100.66.6.109 (100.66.6.109) 14.791 ms *
 6 100.65.14.131 (100.65.14.131) 1.026 ms 100.66.5.189 (100.66.5.189) 19.246 ms 100.66.5.2
 7 100.65.13.143 (100.65.13.143) 14.254 ms 100.95.18.131 (100.95.18.131) 0.944 ms 100.95.1
 8 100.95.2.143 (100.95.2.143) 0.680 ms 100.100.4.46 (100.100.4.46) 1.392 ms 100.95.18.143
 9 100.100.20.76 (100.100.20.76) 7.819 ms 100.92.11.36 (100.92.11.36) 18.669 ms 100.100.20
10 100.92.11.112 (100.92.11.112) 17.852 ms * 100.92.11.158 (100.92.11.158) 16.687 ms
11 100.92.211.82 (100.92.211.82) 19.713 ms 100.92.0.126 (100.92.0.126) 18.603 ms 52.93.112
12 99.83.69.207 (99.83.69.207) 17.603 ms 15.827 ms 17.351 ms
13 100.92.9.83 (100.92.9.83) 17.894 ms 100.92.79.136 (100.92.79.136) 21.250 ms 100.92.9.11
14 172.67.69.208 (172.67.69.208) 17.976 ms 16.945 ms 100.92.9.3 (100.92.9.3) 17.709 ms

```

```

user@AttackBox$ traceroute tryhackme.com
traceroute to tryhackme.com (104.26.11.229), 30 hops max, 60 byte packets
 1 ec2-79-125-1-9.eu-west-1.compute.amazonaws.com (79.125.1.9) 1.475 ms * ec2-3-248-240-31.eu-west-1.compute.amazonaws.com (3.
 2 100.65.20.160 (100.65.20.160) 16.575 ms 100.66.8.226 (100.66.8.226) 23.241 ms 100.65.23.192 (100.65.23.192) 22.267 ms
 3 100.66.16.50 (100.66.16.50) 2.777 ms 100.66.11.34 (100.66.11.34) 22.288 ms 100.66.16.28 (100.66.16.28) 4.421 ms
 4 100.66.6.47 (100.66.6.47) 17.264 ms 100.66.7.161 (100.66.7.161) 39.562 ms 100.66.10.198 (100.66.10.198) 15.958 ms
 5 100.66.5.123 (100.66.5.123) 20.099 ms 100.66.7.239 (100.66.7.239) 19.253 ms 100.66.5.59 (100.66.5.59) 15.397 ms
 6 * 100.66.5.223 (100.66.5.223) 16.172 ms 100.65.15.135 (100.65.15.135) 0.424 ms
 7 100.65.12.135 (100.65.12.135) 0.390 ms 100.65.12.15 (100.65.12.15) 1.045 ms 100.65.14.15 (100.65.14.15) 1.036 ms
 8 100.100.4.16 (100.100.4.16) 0.482 ms 100.100.20.122 (100.100.20.122) 0.795 ms 100.95.2.143 (100.95.2.143) 0.827 ms
 9 100.100.20.86 (100.100.20.86) 0.442 ms 100.100.4.78 (100.100.4.78) 0.347 ms 100.100.20.20 (100.100.20.20) 1.388 ms
10 100.92.212.20 (100.92.212.20) 11.611 ms 100.92.11.54 (100.92.11.54) 12.675 ms 100.92.11.56 (100.92.11.56) 10.835 ms
11 100.92.6.52 (100.92.6.52) 11.427 ms 100.92.6.50 (100.92.6.50) 11.033 ms 100.92.210.50 (100.92.210.50) 10.551 ms
12 100.92.210.139 (100.92.210.139) 10.026 ms 100.92.6.13 (100.92.6.13) 14.586 ms 100.92.210.69 (100.92.210.69) 12.032 ms
13 100.92.79.12 (100.92.79.12) 12.011 ms 100.92.79.68 (100.92.79.68) 11.318 ms 100.92.80.84 (100.92.80.84) 10.496 ms
14 100.92.9.27 (100.92.9.27) 11.354 ms 100.92.80.31 (100.92.80.31) 13.000 ms 52.93.135.125 (52.93.135.125) 11.412 ms
15 150.222.241.85 (150.222.241.85) 9.660 ms 52.93.135.81 (52.93.135.81) 10.941 ms 150.222.241.87 (150.222.241.87) 16.543 ms
16 100.92.228.102 (100.92.228.102) 15.168 ms 100.92.227.41 (100.92.227.41) 10.134 ms 100.92.227.52 (100.92.227.52) 11.756 ms
17 100.92.232.111 (100.92.232.111) 10.589 ms 100.92.231.69 (100.92.231.69) 16.664 ms 100.92.232.37 (100.92.232.37) 13.089 ms
18 100.91.205.140 (100.91.205.140) 11.551 ms 100.91.201.62 (100.91.201.62) 10.246 ms 100.91.201.36 (100.91.201.36) 11.368 ms
19 100.91.205.79 (100.91.205.79) 11.112 ms 100.91.205.83 (100.91.205.83) 11.040 ms 100.91.205.33 (100.91.205.33) 10.114 ms
20 100.91.211.45 (100.91.211.45) 9.486 ms 100.91.211.79 (100.91.211.79) 13.693 ms 100.91.211.47 (100.91.211.47) 13.619 ms
21 100.100.6.81 (100.100.6.81) 11.522 ms 100.100.68.70 (100.100.68.70) 10.181 ms 100.100.6.21 (100.100.6.21) 11.687 ms
22 100.100.65.131 (100.100.65.131) 10.371 ms 100.100.92.6 (100.100.92.6) 10.939 ms 100.100.65.70 (100.100.65.70) 23.703 ms
23 100.100.2.74 (100.100.2.74) 15.317 ms 100.100.66.17 (100.100.66.17) 11.492 ms 100.100.88.67 (100.100.88.67) 35.312 ms
24 100.100.16.16 (100.100.16.16) 19.155 ms 100.100.16.28 (100.100.16.28) 19.147 ms 100.100.2.68 (100.100.2.68) 13.718 ms
25 99.83.89.19 (99.83.89.19) 28.929 ms * 21.790 ms
26 104.26.11.229 (104.26.11.229) 11.070 ms 11.058 ms 11.982 ms

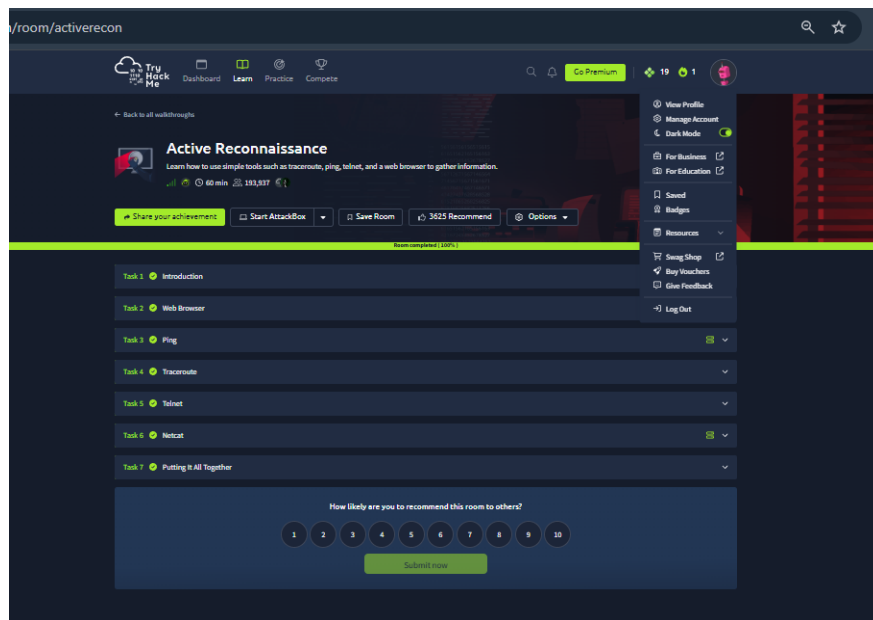
```

Security Impact

- Attackers can use disclosed information to identify exploitable services
- Network mapping improves targeting accuracy during attacks
- Exposed service versions may allow vulnerability matching

Recommendations

- Disable unnecessary service banners and metadata exposure
- Restrict ICMP responses where appropriate
- Limit traceroute visibility through firewall configurations
- Replace insecure protocols such as Telnet with SSH
- Minimize publicly exposed technical information



OWASP Juice Shop Summary

Key Findings

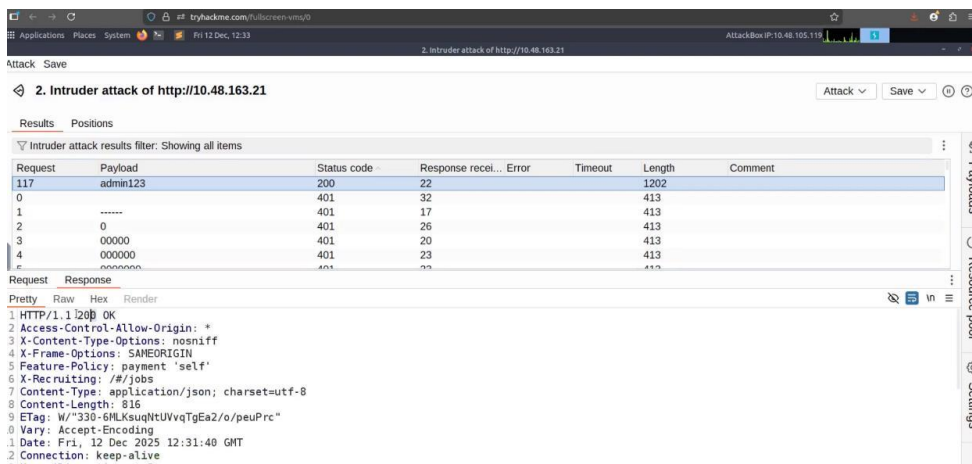
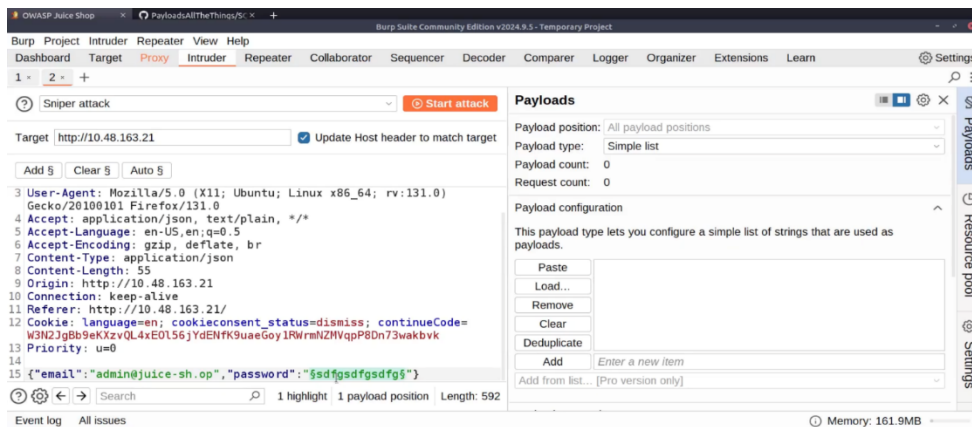
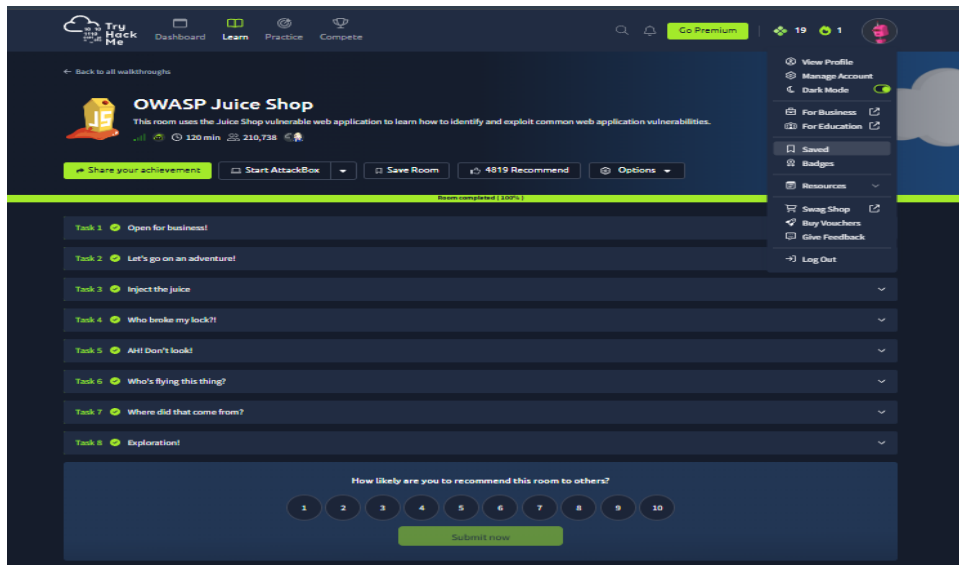
- Sensitive information disclosure through application functionality
- Broken authentication allowing login bypass
- SQL Injection vulnerabilities in authentication forms

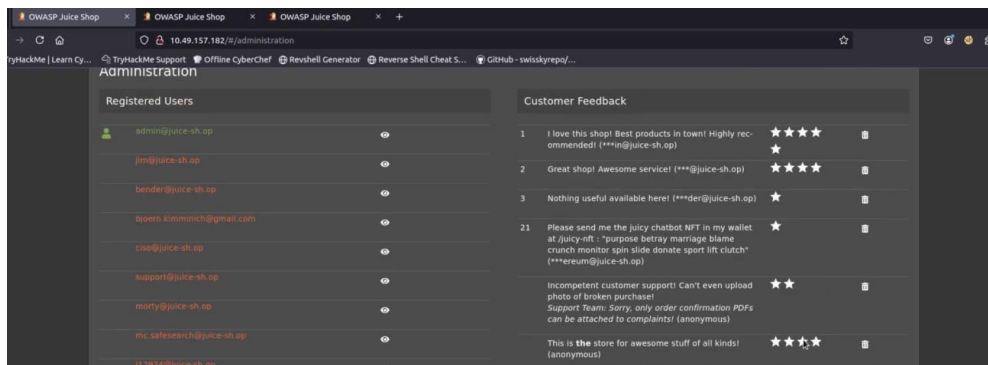
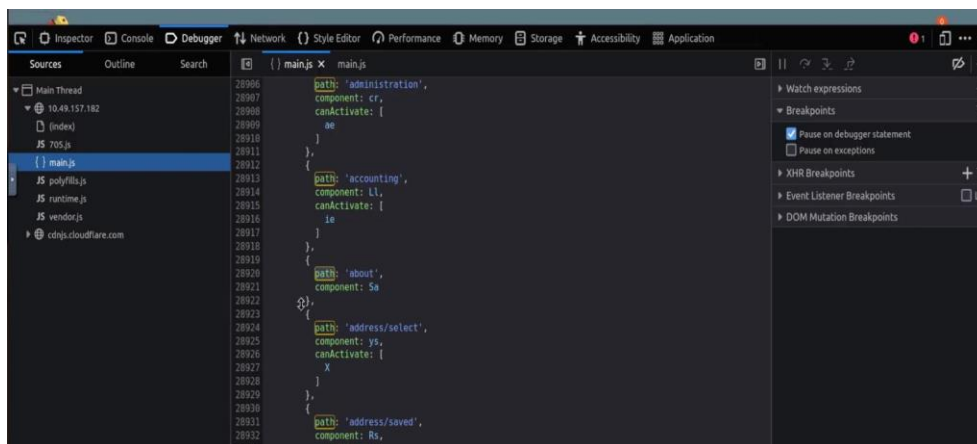
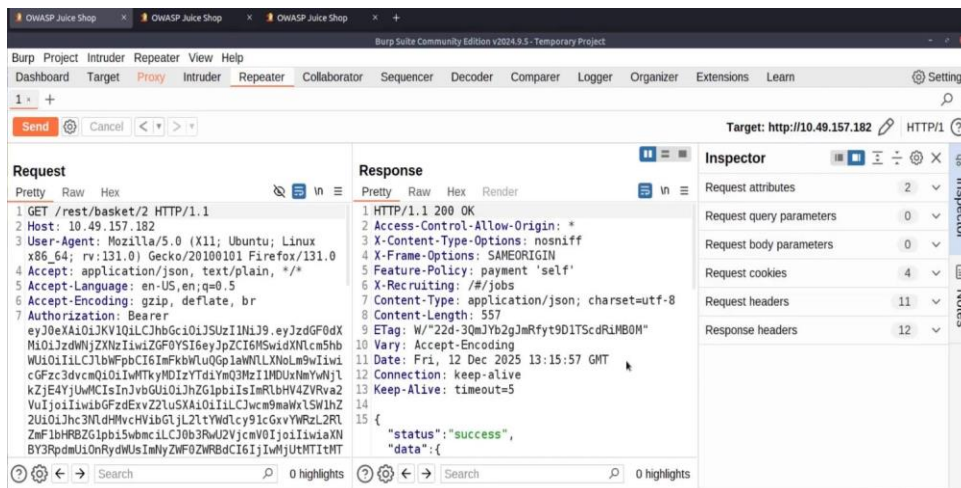
Security Impact

- Unauthorized access to user and administrator accounts
- Potential exposure of sensitive customer data
- Possibility of privilege escalation and database compromise

Recommendations

- Use parameterized queries and prepared statements
- Validate and sanitize all user inputs
- Implement secure session and authentication controls
- Enforce strong password policies and MFA where applicable
- Conduct secure code reviews and regular application testing





Blue Room Summary

Vulnerability

MS17-010 (EternalBlue SMB Vulnerability)

Key Findings

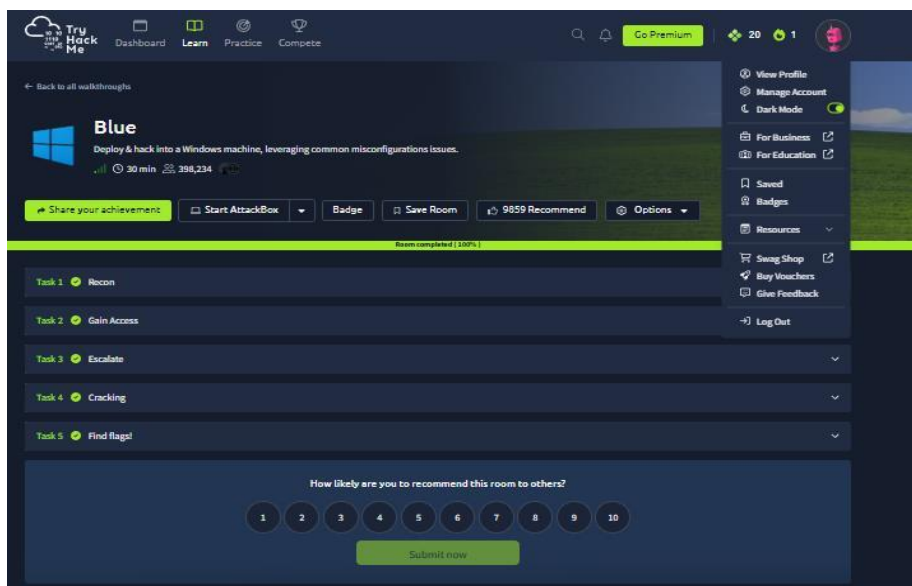
- SMB service exposed on TCP port 445
- Successful remote code execution using EternalBlue exploit
- SYSTEM-level privileges obtained
- Credential hashes successfully extracted and cracked

Security Impact

- Complete system compromise
- Credential theft enabling lateral movement
- Unauthorized access to sensitive system resources
- Potential spread of malware or ransomware across networks

Recommendations

- Apply Microsoft MS17-010 security patches immediately
- Disable SMBv1 protocol
- Restrict access to port 445 using firewall rules
- Enable endpoint protection and credential protection features
- Monitor SMB traffic for suspicious activity



General Security Recommendations

- Maintain regular patch management processes
- Use secure coding practices throughout development
- Perform routine vulnerability assessments and penetration testing
- Disable outdated and insecure protocols/services
- Implement centralized logging and monitoring
- Apply the principle of least privilege
- Conduct security awareness training for users and administrators
- Use endpoint detection and response (EDR) solutions

Conclusion

The assessments demonstrate how weak configurations, insecure application design, and outdated systems can expose organizations to serious cybersecurity threats. Vulnerabilities such as SQL Injection and EternalBlue can allow attackers to gain unauthorized access, escalate privileges, and compromise entire systems.

Organizations can significantly reduce these risks by implementing secure development practices, maintaining proper patch management, restricting unnecessary services, and continuously monitoring their environments for suspicious activity.